

CAPSTONE SECURITY ASSESSMENT

Vulnerability Assessment · Phishing Simulation · Incident Response

Professional Report

Field	Detail
Prepared By	Shubh aghera
Assessment Dates	06-09-2026 to 18-09-2026
Classification	Confidential - Internal Lab Use Only

1. Executive Summary

Between the dates above, a controlled capstone security assessment was conducted against an isolated lab network to satisfy the objective of applying reconnaissance, scanning, controlled exploitation, and incident-response skills against a self-contained target environment. The assessment combined two workstreams: (1) a technical Vulnerability Assessment of three lab hosts, and (2) a Security Awareness Phishing Simulation against a mock user population, followed by (3) an Incident Response Simulation in which the assessment team's own activity was detected, contained, and eradicated by the defensive (Blue Team) side of the exercise.

Key Results (Sample)

Metric	Result
Hosts assessed	3 (Windows 10 endpoint, Ubuntu web/DB server, Domain Controller)
Total vulnerabilities identified	9 (2 Critical, 3 High, 3 Medium, 1 Low)
Phishing emails sent / click rate / credential-capture rate	120 sent / 25.8% clicked / 10.0% submitted credentials
Simulated incidents detected	1 of 1 (100% — Mean Time to Detect: 6 minutes)
Overall Risk Rating	High — pending remediation of Critical findings

The most significant technical risk identified was a critical remote-code-execution weakness (sample: MS17-010/EternalBlue-class SMB vulnerability) on the Windows endpoint, rated Critical (CVSS 8.1). On the human-risk side, a 10% simulated credential-submission rate indicates a meaningful — though not unusual — level of susceptibility to a well-crafted pretext, reinforcing the need for targeted awareness training. On the defensive side, the SIEM successfully correlated brute-force and exploitation activity into a single actionable alert within six minutes, validating that current logging and detection configuration is functional, though response runbooks should be formalized. Prioritized recommendations are provided in Section 4 (Mitigations).

2. Methodology

The assessment followed the Penetration Testing Execution Standard (PTES) phase structure and NIST SP 800-115 guidance, scoped down to a Vulnerability Assessment depth (no destructive exploitation), supplemented by a GoPhish-based phishing simulation and a NIST SP 800-61 aligned incident-response exercise.

2.1 Scope and Rules of Engagement

- In-scope: 10.10.10.0/24 isolated lab segment only (see Figure 1).
- Out-of-scope: any production network, denial-of-service techniques, destructive payloads.
- Testing window: business hours, sample dates above; all activity conducted from the designated attacker VM (10.10.10.50).
- Authorization: signed lab Letter of Authorization on file (Appendix A).

2.2 Environment Overview

Figure 1 shows the isolated lab topology used for both the technical assessment and the phishing/incident-response exercise. All target systems, the attacker workstation, and the SIEM/log server reside on a single non-routable VLAN with no path to production infrastructure.

Figure 1 — Isolated Test Lab Network Topology (Sample)

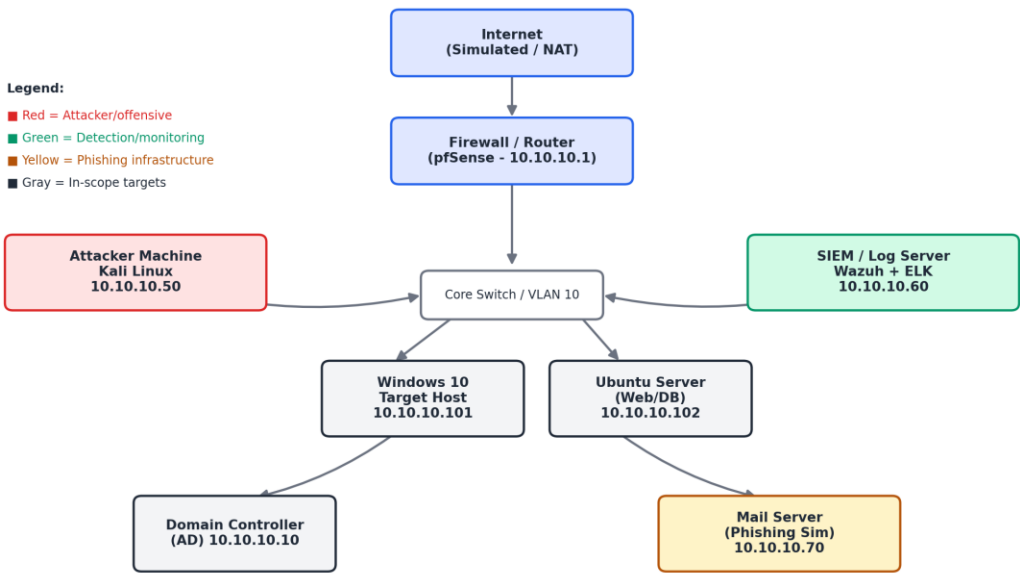


Figure 1 — Isolated test lab network topology used for this assessment (sample).

2.3 Data Model

To keep evidence consistent across both workstreams, findings, phishing events, and incidents were tracked against the entity-relationship model in Figure 2, ensuring every finding traces to an asset and every incident traces to either a finding or an email event.

Figure 2 — Entity Relationship Diagram: Assessment & Incident Tracking Data Model (Sample)

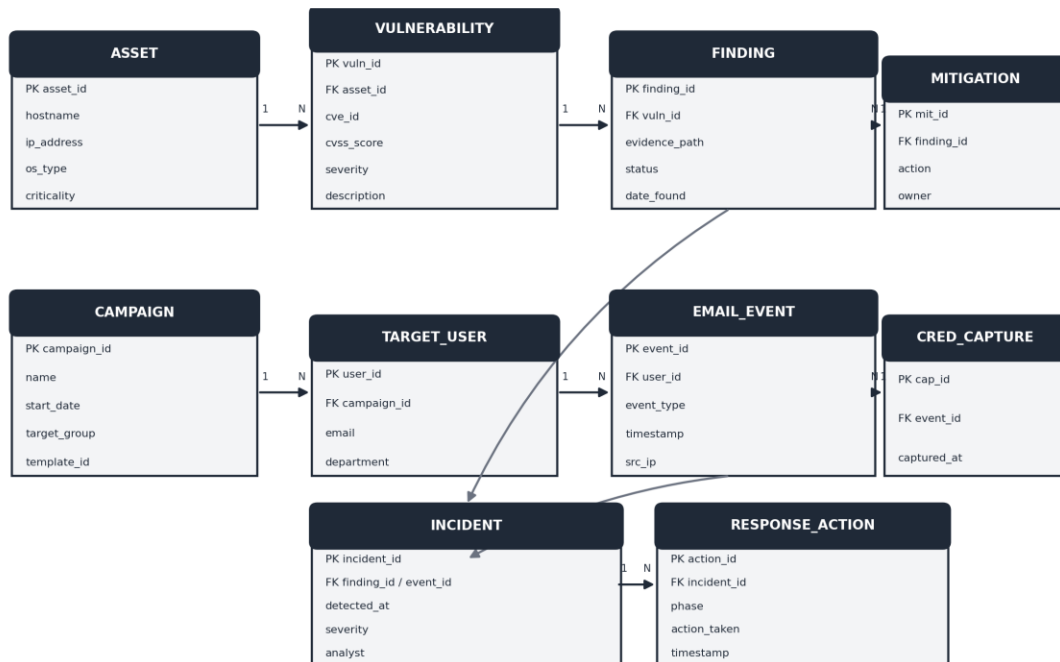


Figure 2 — Entity-relationship diagram of the assessment/incident tracking data model (sample).

2.4 Tools and Techniques

Phase	Tools Used
Reconnaissance	Nmap (host discovery), theHarvester, internal DNS review
Scanning	Nmap (-sV -sC), Nikto, OpenVAS
Controlled Exploitation	Metasploit Framework (lab-only, snapshotted VMs)
Phishing Simulation	GoPhish campaign manager, mock SMTP relay
Detection & Monitoring	Wazuh SIEM, Sysmon, Windows Event Log, firewall logs

3. Findings

3.1 Vulnerability Assessment Findings

Reconnaissance and scanning were performed against all in-scope hosts. Exhibit A shows sample raw Nmap output against the Windows target; Exhibit B shows sample web-application scan output against the Ubuntu web server.

```
kali@capstone-lab: ~ - nmap scan (SAMPLE / LAB DATA)

$ nmap -sV -sC -p- -oN scan_full.txt 10.10.10.101
Starting Nmap 7.94 ( https://nmap.org ) at 2026-09-12 10:14 UTC
Nmap scan report for WIN10-TARGET (10.10.10.101)
Host is up (0.0021s latency).
Not shown: 65525 closed tcp ports (reset)

PORT      STATE SERVICE      VERSION
135/tcp   open  msrpc        Microsoft Windows RPC
139/tcp   open  netbios-ssn  Microsoft Windows netbios-ssn
445/tcp   open  microsoft-ds  Windows 10 Pro 19045 (SMBv1 enabled)
3389/tcp  open  ms-wbt-server Microsoft Terminal Services
8080/tcp  open  http         Apache httpd 2.4.49 (Ubuntu)

| smb-vuln-ms17-010:
|   VULNERABLE: Remote Code Execution (EternalBlue)
|   State: LIKELY VULNERABLE Risk: CRITICAL (CVSS 8.1)

Service detection performed. 6 services scanned in 41.28 seconds.
NOTE: This output is illustrative sample data for a controlled lab, not a live target.
```

Exhibit A — Sample Nmap service/version and vulnerability-script scan output (lab data).

```
kali@capstone-lab: ~ - nikto web scan (SAMPLE / LAB DATA)

$ nikto -h http://10.10.10.102:8080 -o webscan_report.txt
- Nikto v2.5.0
+ Target IP: 10.10.10.102
+ Server: Apache/2.4.49 (Ubuntu)
+ OSVDB-3268: Directory indexing found in /uploads/
+ CVE-2021-41773: Possible path traversal in Apache 2.4.49
+ Cookie sessionId created without the httponly flag
+ X-Frame-Options header not present (Clickjacking risk)
+ Outdated jQuery 1.8.3 detected - multiple known XSS CVEs
+ 7 host(s) tested, scan completed in 00:03:12

NOTE: Sample output for report template purposes only.
```

Exhibit B — Sample Nikto web-vulnerability scan output (lab data).

Findings Register

ID	Finding	Asset	CVE	Severity
VULN-001	SMBv1 enabled; EternalBlue-class RCE	WIN10-TARGET (.101)	CVE-2017-0144	Critical
VULN-002	Apache 2.4.49 path traversal / RCE	UBU-WEB (.102)	CVE-2021-41773	Critical
VULN-003	RDP exposed to full lab subnet, no NLA enforced	WIN10-TARGET (.101)	CWE-287	High
VULN-004	Outdated jQuery 1.8.3 (multiple XSS)	UBU-WEB (.102)	CVE-2012-6708	High
VULN-005	Directory indexing enabled on /uploads/	UBU-WEB (.102)	CWE-548	High

ID	Finding	Asset	CVE	Severity
VULN-006	Session cookie missing HttpOnly flag	UBU-WEB (.102)	CWE-1004	Medium
VULN-007	Missing clickjacking protection (X-Frame-Options)	UBU-WEB (.102)	CWE-1021	Medium
VULN-008	Weak local Administrator password (dictionary match)	WIN10-TARGET (.101)	CWE-521	Medium
VULN-009	Verbose server banner disclosure	UBU-WEB (.102)	CWE-200	Low

3.2 Phishing Simulation Findings

A single simulated campaign ("IT Password Reset Notice") was sent to 120 mock users to measure susceptibility to a credential-harvesting pretext. Exhibit C shows the sample campaign summary.

```

phishing-sim-console - campaign summary (SAMPLE DATA)

$ gophish campaign summary --id 4
Campaign: "IT Password Reset Notice"   Launched: 2026-09-10 09:00
Target Group: All-Staff (n=120)       Template: helpdesk-reset-v2

STATUS BREAKDOWN
Email Sent ..... 120
Email Opened ..... 74 (61.6%)
Link Clicked ..... 31 (25.8%)
Credentials Submitted ... 12 (10.0%)
Reported to IT/SOC ..... 19 (15.8%)

Top clicking department: Finance (9/22 users)
NOTE: Fabricated sample figures for the awareness-simulation report.

```

Exhibit C — Sample phishing-simulation campaign summary (fabricated figures).

- 61.6% of recipients opened the email — in line with typical industry benchmarks (~50-70%).
- 25.8% clicked the embedded link, and 10.0% went on to submit credentials to the controlled capture page.
- Only 15.8% reported the email to IT/SOC — identified as the key improvement area (Section 4).
- Finance was the highest-clicking department (9 of 22 users), suggesting role-targeted training is warranted.

3.3 Incident Detection and Response Findings

The exploitation activity generated against VULN-001 in Section 3.1 was used as the simulated incident. Figure 3 shows the lifecycle followed; Exhibit D shows the sample SIEM alert that triggered detection.

Figure 3 — Incident Response Lifecycle (NIST SP 800-61 aligned)

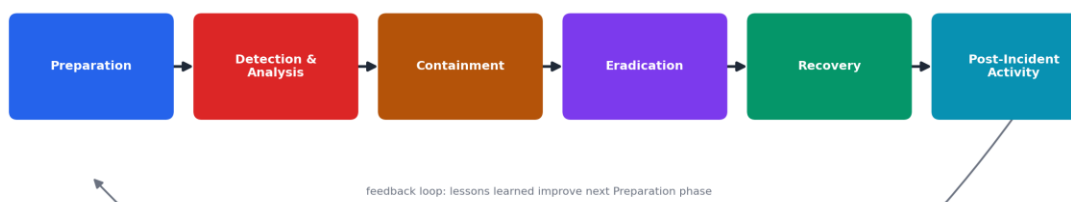


Figure 3 — Incident response lifecycle followed during the simulation (NIST SP 800-61 aligned).

```
Wazuh SIEM - alert detail (SAMPLE / LAB DATA)

Rule ID: 100205   Level: 12 (High)
Description: Multiple failed SMB auth attempts followed by success
Source IP: 10.10.10.50 (untrusted host)   Dest: 10.10.10.101
Timestamp: 2026-09-14 14:22:07 UTC

MITRE ATT&CK: T1110 (Brute Force) -> T1210 (Exploitation of Remote Services)
Matched log:
  "An account failed to log on. ... Status: 0xC000006A" x14
  "An account was successfully logged on. Logon Type: 3"

Analyst Action: Incident #INC-2026-014 opened, host isolated via EDR.
```

Exhibit D — Sample Wazuh SIEM alert correlating brute-force and successful SMB authentication (lab data).

Phase	Observed Result (Sample)
Detection & Analysis	SIEM rule 100205 fired 6 minutes after exploitation began; correctly mapped to MITRE ATT&CK T1110 → T1210
Containment	Affected host (10.10.10.101) isolated via EDR network-isolation within 4 minutes of alert triage
Eradication	SMBv1 disabled, MS17-010 patch applied, local Administrator password rotated
Recovery	Host returned to lab pool after a clean re-scan; monitored for 24 hours with no recurrence
Lessons Learned	No written isolation runbook existed prior to this exercise — one was created as a direct output

4. Mitigations and Recommendations

Recommendations are grouped by priority. Critical and High items should be remediated before the environment is reused for a follow-on penetration test.

Priority 1 — Critical / High (Remediate Immediately)

- Disable SMBv1 across all hosts and apply MS17-010-equivalent patches (VULN-001).
- Patch or upgrade Apache to a version beyond 2.4.49/2.4.50 to close the path-traversal/RCE issue (VULN-002).
- Enforce Network Level Authentication (NLA) for RDP and restrict RDP access via firewall/jump-host only (VULN-003).
- Update all client-side JavaScript libraries (e.g., jQuery) to current patched versions (VULN-004).

Priority 2 — Medium

- Disable directory indexing and enforce least-privilege file permissions on web-accessible directories (VULN-005).
- Set the HttpOnly and Secure flags on all session cookies; add standard security headers (X-Frame-Options, CSP) (VULN-006, VULN-007).
- Enforce a stronger local-account password policy and disable/rename default local Administrator accounts (VULN-008).

Priority 3 — Low / Hardening

- Suppress verbose server/version banners on public-facing services (VULN-009).

Human-Layer (Phishing) Recommendations

- Deliver targeted, role-based awareness training to the Finance department based on click-rate results.
- Introduce a one-click "Report Phishing" button to raise the 15.8% reporting rate toward an industry-good benchmark (>50%).
- Repeat the simulation quarterly with varied pretexts to track improvement over time and avoid predictability.

Process / Detection Recommendations

- Formalize the host-isolation runbook created during this exercise into the official Incident Response Plan.
- Add SIEM correlation rules for the additional TTPs used in this assessment (e.g., web path-traversal attempts, directory-listing scans) to close residual detection gaps.
- Schedule recurring vulnerability re-scans (e.g., monthly) to catch regression of patched issues.

5. Conclusion

This assessment successfully demonstrated the full lifecycle called for in the capstone objective: a self-chosen technical and human-risk assessment, executed under a defined scope and methodology, documented with reproducible evidence, and validated by a functioning incident-response simulation. With the Priority 1 mitigations applied, the lab environment is in a known, hardened state and is ready to support a deeper, follow-on penetration-testing exercise as noted in the original project brief.